

ABHIJEET PATHAK

SENIOR SECURITY CONSULTANT

+91 9109069565 | abhijeetpathak9826@gmail.com

PROFILE SUMMARY

Security Professional with 5 years of expertise in advanced Penetration Testing across Web, Network, GenAI, Mobile, and APIs, with a proven specialization in infrastructure and emerging technologies. My core expertise includes executing comprehensive Active Directory penetration tests, uncovering multiple paths to domain compromise, and leading network segmentation reviews utilizing industry tools like Nessus and Nipper to evaluate critical network components. I actively address emerging threats by spearheading GenAI Penetration Testing for multiple clients, including chatbots, and collaborating on cloud security initiatives and infrastructure assessments. I leverage Bash and Python scripting to develop multiple internal automation scripts and Burp extensions—such as an SQLi detector and JS analysis tools—significantly enhancing team efficiency and product capabilities, including an AI-powered reporting algorithm for a company security product (GAP). This technical proficiency is complemented by demonstrated leadership, including leading advanced technical interview loops for consultant candidates and training newly hired peers. My proven track record of finding critical flaws is evidenced by a personal CVE (CVE-2022-4314) and 50+ Hall of Fame/Bug Bounty awards from major companies.

SKILLS

- | | | | |
|-----------------------------|--|--------------------------------|--|
| • Web Penetration Testing | • Mobile Penetration Testing | • Python Scripting | • AWS Configuration Review |
| • API Penetration Testing | • Cloud Security | • OSINT | • Active Directory Review |
| • Attack Surface Management | • Bash Scripting | • External Network Penetration | • Internal Network Penetration Testing |
| • GenAI Penetration Testing | • Active Directory Penetration Testing | | |

WORK EXPERIENCE

Offensive Senior Security Consultant | Kroll

October, 2023 – Present

- Conducted comprehensive penetration testing across web applications, mobile platforms, and APIs for diverse clients, including those in the banking, telecommunications, and cloud services sectors.
- Led security configuration reviews and network segmentation assessments, utilizing both manual techniques and automated tools like Nessus and Nipper to evaluate firewalls and other network components.
- Collaborated as an integral member of a cloud service provider's internal security team, focusing on cloud security initiatives and infrastructure assessments.
- Executed both internal and external infrastructure security assessments, identifying vulnerabilities and recommending mitigation strategies.
- Performed thorough code reviews using a combination of manual analysis and automated tools to identify and rectify security flaws.
- Led client-facing meetings, including Project Kick-Offs (PKOs), status updates, and readout calls, ensuring clear communication of findings and recommendations.
- Initiated and implemented team-wide reporting enhancements, resulting in improved clarity and effectiveness of final deliverables.
- Led threat modeling initiatives to systematically identify and assess potential security risks, guiding the formulation of targeted mitigation strategies.
- Took the lead in training newly hired peers, ensuring they were well-prepared and confident in their roles from day one.
- Performed GenAI Penetration Testing for multiple clients, including chatbots, downstream services, and vibe coding agents.
- Conducted Active Directory reviews and penetration test assessments for multiple clients, uncovering multiple paths to compromise the domain.
- Developed multiple internal automation scripts and Burp extensions to enhance team efficiency, including JS analysis tools, code review tools, NPM dependencies analysis tools, and an SQLi detector.
- Contributed to the company's security product, GAP, to enhance its capabilities by adding new security checks and developing an AI-powered, fully automatic reporting and correlation algorithm.
- Led technical interview loops for consultant candidates, specializing in evaluating hands-on skills in penetration testing to ensure a high standard of technical proficiency.

Security Consultant | RedHunt Labs

Dec, 2021 – Sept, 2023

- Worked on Web Applications, APIs and Android Applications, found high level vulnerabilities like RCE, SSRF with aws metadata access bypassing firewall and whitelisting, SQL Injection bypassing Cloudflare, AWS WAF, etc both manual and using tools, LFI, etc.
- Attack Surface Management of wide attack surface of numerous clients across the globe and found high impactful vulnerabilities and data leaks.
- Used tools such as BurpSuite, Nessus, Nmap, SQLmap, Postman, etc.
- Managed Company's biggest clients which had 2lacs+ assets every month using automation and manual approach, coordinated with clients for resolving issues. Prepared Test cases Reports and POCs.
- Developed tools in Bash, Python and Go for automating vulnerability findings and repetitive tasks.

Associate Security Consultant | SecurityBulls Intelligence

June, 2021 – Dec, 2021

- Worked on Web Applications, APIs and Android Applications, found high level vulnerabilities.
- Used tools such as BurpSuite, Nmap, SQLmap, Postman, etc.
- Conducted Dynamic Application Security Testing (DAST) and source code review of web and mobile applications using automated and manual approach.
- Developed tools in Bash and Python for automating repetitive tasks.

EDUCATION

Bachelor's of Technology | Samrat Ashok Technological Institute

2018–2022

ACHIVEMENTS AND CERTIFICATIONS

- CVE-2022-4314 – <https://nvd.nist.gov/vuln/detail/CVE-2022-4314>
- Hall of fame and Bounties from 50+ companies like Cloudflare, Dell, Twitter, Microsoft, Latoken, Lachian, Bitgo, Intermedia, Lacework, Preplounge, Anycoindirect, Panther labs, Sixt, Wallethub, USEFYI and more.
- Practical ethical hacking – The complete course Heath Adams, ICSI | CNSS Certified Network Security Specialist, Python for Pentesters CodeRed – EC council, Ethical Hacking Course – Zaid Zsecurity, Automate Boring Stuff with python – Udemy

PERSONAL PROJECTS

- Open sourced a Github Recon automation tool known as GitSki written in python which bypasses the github restrictions and scan effectively. – <https://github.com/neverjunior/GitSki>
- Fine-tuned a LLM model and created a Subdomain prediction tool.
- JavaScript Analysis tool, which monitors the JS in real time and find secrets and new endpoints leveraging AI and Abstract Syntax Tree.
- Parshu is a script written mainly in bash for automating bugs and recon process like lfi, xss, sql, ssrf, fuzzing, waybackurls, github recon, shodan, etc.
- Source Code Analyzer which takes all the valid directories and webpages from waybackurls, fuzzing and find secrets, endpoints using regex.
- Subdomain Finding framework which uses few of my own written modules and open source tools for finding subdomains via different methods (Active and Passive), in a recursive way.
- Internal scripts and tools for automating repetitive processes, quickly testing millions of assets, and identifying vulnerabilities such as sql, xss, open-redirects, Host Header Injection, CORS Misconfiguration, etc.